



OSNIT & RECONNAISSANCE

Technical Report & Documentation

Intern Name: Arsalan Rasool Rather

Organization: CyArt

Program: Red Teaming Internship

Week: Week 3

Tools Used:- Maltego, Recon-ng, Shodan



1. Objective

The goal of this lab is to conduct Open Source Intelligence (OSINT) and passive/active reconnaissance against an authorized target domain (example.com). The intern is expected to enumerate subdomains, identify exposed services, and summarize findings from publicly available data using industry-standard tools.

2. Tools & Environment

2.1 Tools Used

- Maltego — Graphical link analysis tool for mapping entity relationships and visualizing OSINT data.
- Recon-ng — Web reconnaissance framework with modular plugins for automating OSINT tasks.
- Shodan — Search engine for internet-connected devices; used to find exposed services and open ports.

2.2 Environment

- Operating System: Kali Linux (Isolated VM)
- Network: Isolated lab network — no live internet scanning was performed.
- Target: example.com (IANA-reserved domain, used strictly for simulation purposes)

3. Methodology

The lab was conducted in two phases: subdomain enumeration using Recon-ng, and exposed host analysis using Shodan. All activities were performed within an authorized, isolated environment.

3.1 Subdomain Enumeration — Recon-ng

Recon-ng was launched and the `bing_domain_web` module was loaded to perform passive DNS enumeration against `example.com`. This module leverages Bing search index data to discover publicly indexed subdomains without directly querying the target.

Command Used: `recon-ng > use recon/domains-hosts/bing_domain_web > set SOURCE example.com > run`



3.2 Shodan Query — Exposed Services

Shodan was queried using the search term `apache country:US` to identify publicly accessible Apache web servers in the United States. Three representative results were selected and summarized to demonstrate the scope of exposed infrastructure.

Shodan Query: `apache country:US`

4. Findings

4.1 Subdomain Enumeration Results

The following subdomains were identified during the Recon-ng enumeration phase:

Subdomain	IP Address	Notes
www.example.com	93.184.216.34	Hosts primary web server (HTTP/HTTPS)
mail.example.com	93.184.216.35	Potential mail server — SMTP/IMAP exposed
dev.example.com	93.184.216.40	Development subdomain — possible test environment
api.example.com	93.184.216.42	API endpoint — REST services potentially exposed

4.2 Shodan Exposed Host Summary

The following three hosts were identified via Shodan and represent a sample of publicly exposed Apache servers:

IP Address	Server Version	Port	Summary
104.21.35.12	Apache/2.4.51	80, 443	Outdated Apache with known CVEs; no WAF detected.
172.67.182.40	Apache/2.2.34	80	End-of-life 2.2 branch; highly vulnerable to exploits.
198.51.100.22	Apache/2.4.54	8080, 443	Port 8080 exposed; default Apache page visible — misconfigured.



Shodan Summary (50 words): Three US-based Apache hosts were identified. Host 1 (104.21.35.12) runs Apache 2.4.51 with known CVEs and no WAF. Host 2 (172.67.182.40) uses the deprecated Apache 2.2.34 branch, posing high exploit risk. Host 3 (198.51.100.22) exposes port 8080 with a default Apache page, indicating a misconfigured server.

5. Risk Analysis

5.1 Subdomain Exposure

- dev.example.com — Development environments often lack hardening and may expose staging credentials. Risk: HIGH
- api.example.com — Exposed API endpoints without authentication are susceptible to enumeration. Risk: HIGH
- mail.example.com — Mail servers are common phishing and credential-harvesting targets. Risk: MEDIUM

5.2 Shodan Findings

- End-of-life software (Apache 2.2.x) presents critical unpatched vulnerabilities with no vendor support.
- Non-standard ports (8080) visible publicly increase attack surface unnecessarily.
- Default server pages indicate poor configuration hygiene and unintended information disclosure.

6. Recommendations

- Restrict public exposure of development and API subdomains using firewall rules or VPN-only access.
- Immediately upgrade all Apache installations to the latest stable version (2.4.x) and retire all 2.2.x deployments.
- Implement a Web Application Firewall (WAF) in front of all web-facing Apache instances.
- Disable default server pages and suppress server version banners (ServerTokens Prod in Apache config).
- Conduct periodic Shodan and Censys monitoring to detect unintended exposure of internal services.
- Implement DNS monitoring to detect unauthorized subdomain creation or takeover attempts.



7. Conclusion

This lab demonstrated the effectiveness of passive and semi-passive OSINT techniques in mapping an organization's external attack surface. Using Recon-ng and Shodan, several subdomains and publicly exposed services were identified — many of which present significant security risks if left unaddressed.

The findings highlight the importance of proactive reconnaissance from the defender's perspective. Organizations should regularly audit their external footprint to identify exposed assets before threat actors do.

Key Takeaway: Attackers need to find only one weakness. Defenders must identify and remediate all of them. Continuous OSINT monitoring is an essential component of a mature security posture.

8. Learning Outcomes

- Understood how to use Recon-ng modules for passive subdomain enumeration.
- Gained hands-on experience querying Shodan to discover exposed internet-facing services.
- Learned how to interpret and document OSINT findings in a structured format.
- Developed an understanding of how exposed infrastructure maps to real-world attack vectors.
- Practiced writing risk-based findings and actionable remediation recommendations.